
CISCO FTD

SSL Decryption & URL Filtering FMC-Managed Configuration Guide

A complete lab walkthrough covering URL Filtering concepts, Access Control rule actions (Block vs Reset, Monitor vs Allow), SSL/TLS Decrypt-Resign with internal CA generation, client certificate trust, decryption policy creation, badssl.com validation, and troubleshooting.

Author: Abdelrhman Nabil

Role: OT/ICS Security Engineer

Category: Network Security Lab · Portfolio Project

Platform: Cisco Firepower (FMC + FTD · SSL Decryption + URL Filtering)

1. Lab Environment

This guide builds on a pre-configured FTD/FMC deployment with interfaces, ACP, NAT, and static routing already in place. The FTD is registered to FMC and has internet connectivity established.

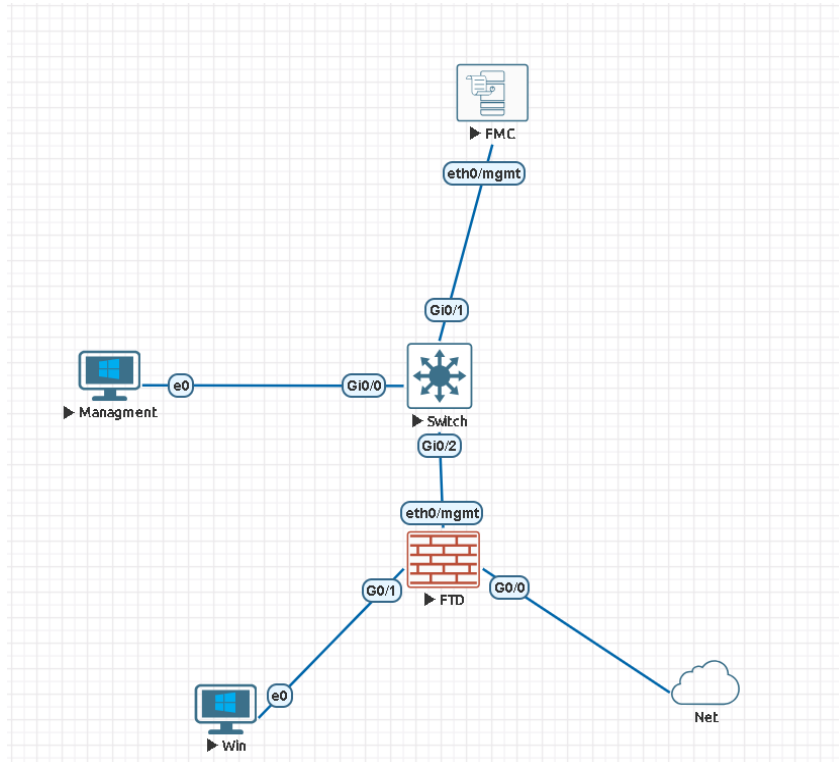


Figure 1 — Lab Topology

☐	Name	Model	V...	Chassis	Licenses	Access Control Policy	Auto RollBack
☐	Ungrouped (1)						
☐	FirePower 192.168.10.2 - Rou	Short	Firewall Threat...	7...	N/A	Essentials	None

Figure 2 — FTD registered in FMC

Interface	Logical Na...	Type	Security Z...	MAC Address (Activ...	IP Address	Path M...	Virtual Ro...
Diagnostic0/0	diagnostic	Phys...				Disabled	Global
GigabitEthernet0/0	Outsidee	Phys...	Outside		192.168.1.111/24(Stati...	Disabled	Global
GigabitEthernet0/1	Inside	Phys...	Inside		192.168.100.1/24(Sta...	Disabled	Global

Figure 3 — Interface configuration (Outside/Inside)

2. What Is URL Filtering?

URL Filtering on Cisco FTD/FMC allows the firewall to classify, enforce, and gain visibility into web traffic based on website categories, reputation scores, and URL paths.

► 2.1 Classify Web Traffic

- Website category (e.g., Social Media, Gambling, Malware Sites)
- Reputation level (Malicious, Suspicious, Trustworthy)
- URL path (e.g., /login, /download)

► 2.2 Enforce Security & Compliance

- Block harmful categories (Malware, Botnets, Phishing)
- Block non-business categories (Adult, Gambling, Entertainment)
- Allow business-critical categories (Finance, Cloud Storage)

► 2.3 Improve Visibility

With URL filtering enabled, FTD provides visibility into:

- Full URL, Category, and Application name
- User identity (if identity policy is enabled)
- Threat reputation score

► 2.4 URL Filtering vs. SSL Decryption

URL Filtering can work without SSL Decryption but with reduced capability:

Feature	Without SSL Decryption	With SSL Decryption
Domain block	Works (via SNI)	Full URL visibility
Application identification	Limited	Full accuracy
Inline malware blocking	Limited	100% enabled

3. Access Control Rule Actions

Understanding the different rule actions is essential before configuring URL filtering or SSL decryption policies.

► 3.1 Block vs. Block with Reset

Feature	Block	Block with Reset
Action	Silent drop	Send TCP RST
Client experience	Connection timeout	Instant error message
Server sees	Nothing	Reset packet
User-friendliness	Low	High
Best for	Threat-based blocking	Policy-based blocking

► 3.2 Monitor vs. Allow

This is a common source of confusion. Understanding the difference is critical for proper policy design:

Feature	Allow	Monitor
Final decision	Permits traffic	No decision (passes to next rule)
Traffic allowed?	Yes	Depends on the next matching rule
Logs traffic?	Yes	Yes
Use case	Enforcement	Visibility / Testing
Stops rule processing?	Yes	No — continues to next rule
Applies IPS/URL/AVC?	Yes	Only if next matching rule allows

4. URL Filtering Configuration

► 4.1 Baseline — Verify Facebook is Accessible

Before applying any URL filtering rules, confirm that Facebook is accessible from the test client to establish a baseline:

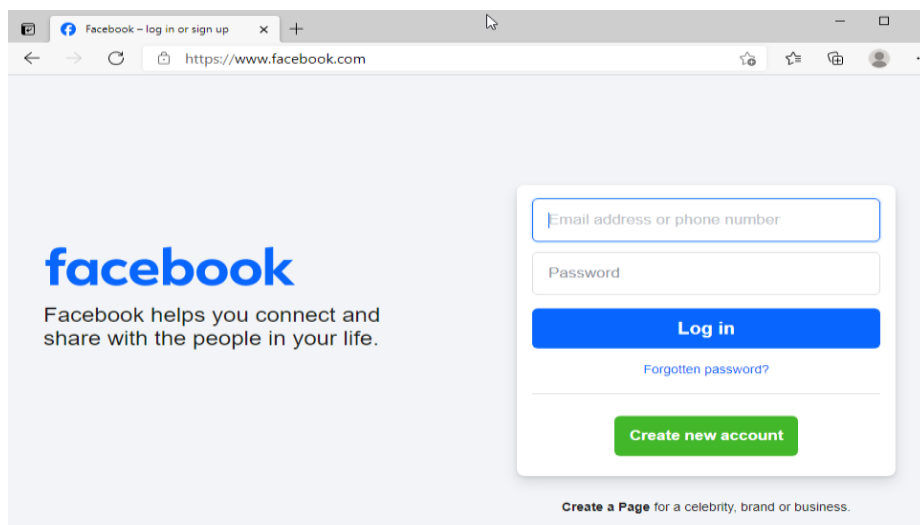


Figure 4 — Facebook accessible before URL filtering

► 4.2 Create the URL Filtering Rule

1. Navigate to Policies → Access Control → Access Control Policies.
2. Edit your main policy.
3. Go to the URLs tab.
4. Create a URL object for facebook.com and apply an Interactive Block action.
5. Set Source Zone: Inside, Destination Zone: Outside, and add the URL object.

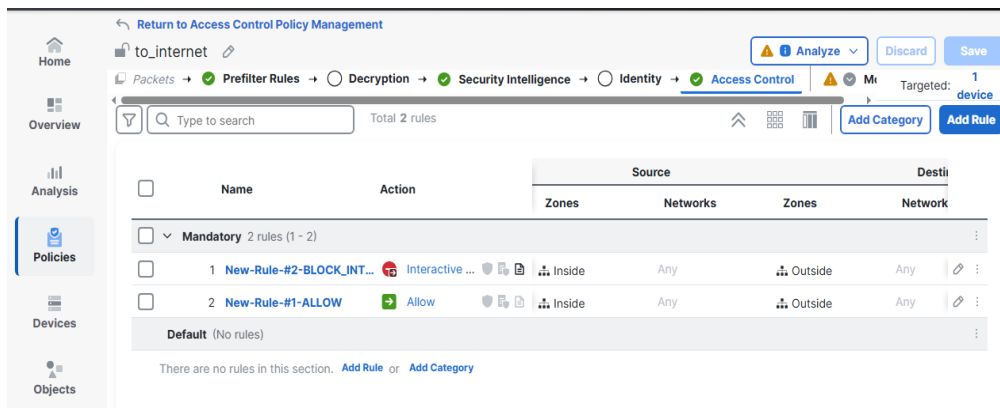


Figure 5 — URL filtering rule: Block facebook.com (Inside → Outside)

Commonly Blocked Categories

- Adult, Gambling, Extremism, Illegal Drugs
- Peer-to-Peer, Hacking, Malicious Sites
- Newly Registered Domains
- Social Networking (optional, depending on policy)

► 4.3 Rule Order (Critical)

Rule ordering in the Access Control Policy is critical — rules are evaluated top-down:

1. Block categories (highest priority)
2. Allow business categories
3. Default rule (Monitor / Block)

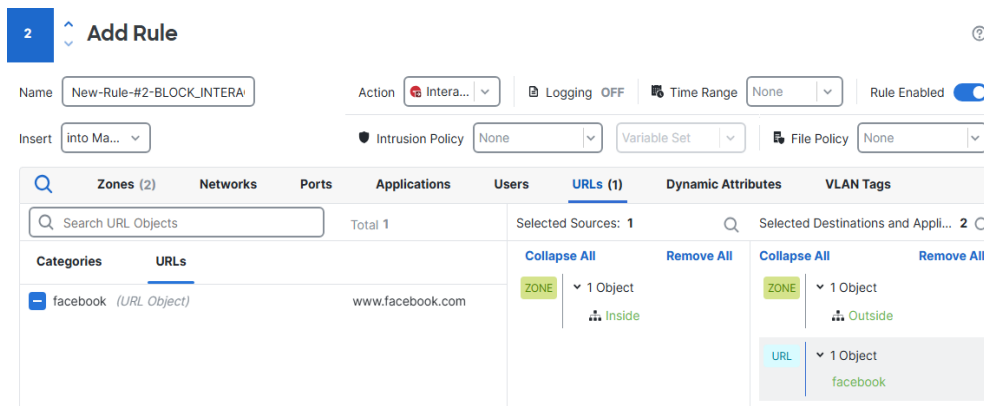


Figure 6 — ACP rule order: Block rule above Allow rule

Enable logging on all rules for full visibility in events. Note: consider storage implications for high-traffic environments.

► 4.4 Deploy & Verify

Click Deploy → Deploy to FTD. Wait 1–3 minutes for the policy to propagate.

After deployment, Facebook should be blocked from the test client:

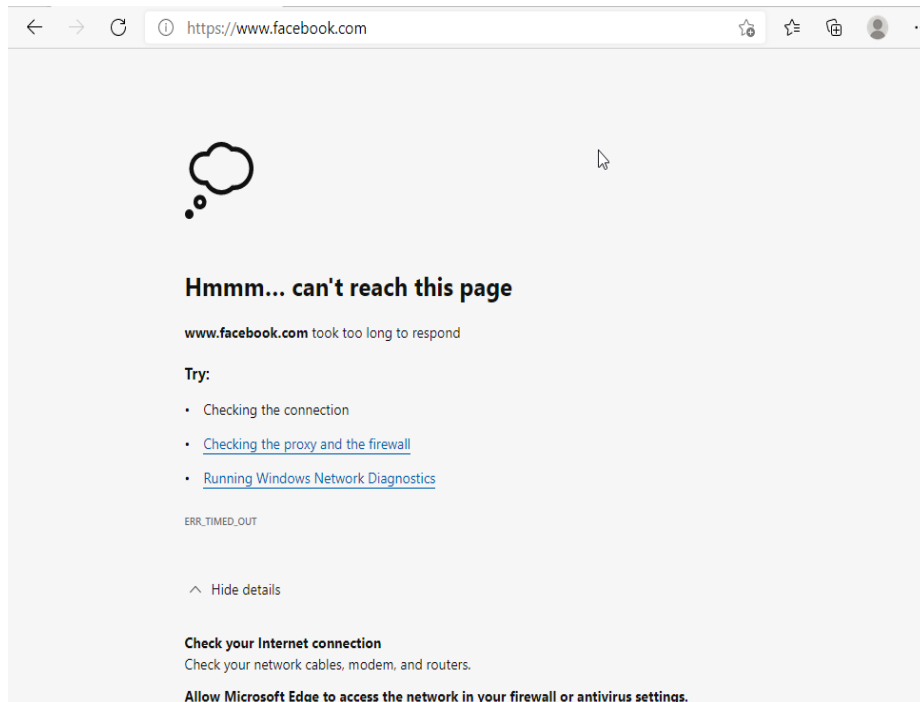


Figure 7 — Facebook blocked after URL filtering deployment

5. SSL Decryption — Concepts

When users browse HTTPS, traffic is encrypted end-to-end. The FTD cannot see URL paths, application details, file downloads, malware, or commands inside HTTPS without decryption.

SSL Decryption breaks the encryption, inspects the traffic, then re-encrypts it:

PC ⇄(TLS1)⇄ FTD ⇄(TLS2)⇄ Internet

- FTD acts as a man-in-the-middle proxy (Decrypt-Re-sign)
- FTD needs a CA certificate to sign re-issued certificates
- Clients MUST trust the FTD's CA; otherwise they see certificate warnings

► 5.1 Four Steps to Implement SSL Decryption

1. Generate a Cisco FTD certificate as Internal CA — this certificate must be trusted by users inside the network.
2. Configure SSL policy to Decrypt and Re-Sign — applicable to all websites or specific ones.
3. Enable SSL policy in ACP — the SSL policy is not applied unless referenced from the Access Control Policy.
4. Test, monitor, and troubleshoot the Decrypt Re-Sign policy.

► 5.2 Asymmetric Encryption Fundamentals

Key	Who Holds It	Purpose
Public Key	Shared with everyone	Encrypt data
Private Key	Kept secret	Decrypt data / sign data

This is the foundation of asymmetric encryption and the basis for SSL/TLS certificate trust.

6. Generate Internal CA Certificate

This is the most important step. The Internal CA certificate is what FTD uses to re-sign decrypted traffic.

1. Navigate to Objects → Object Management.
2. Under PKI, click Internal CAs → Generate CA.

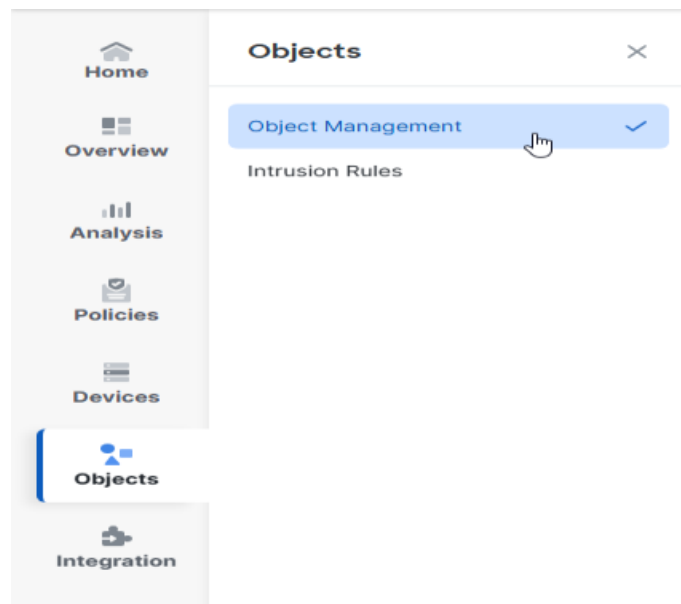


Figure 8 — Objects → Object Management → PKI

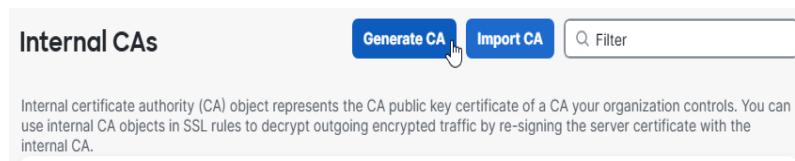
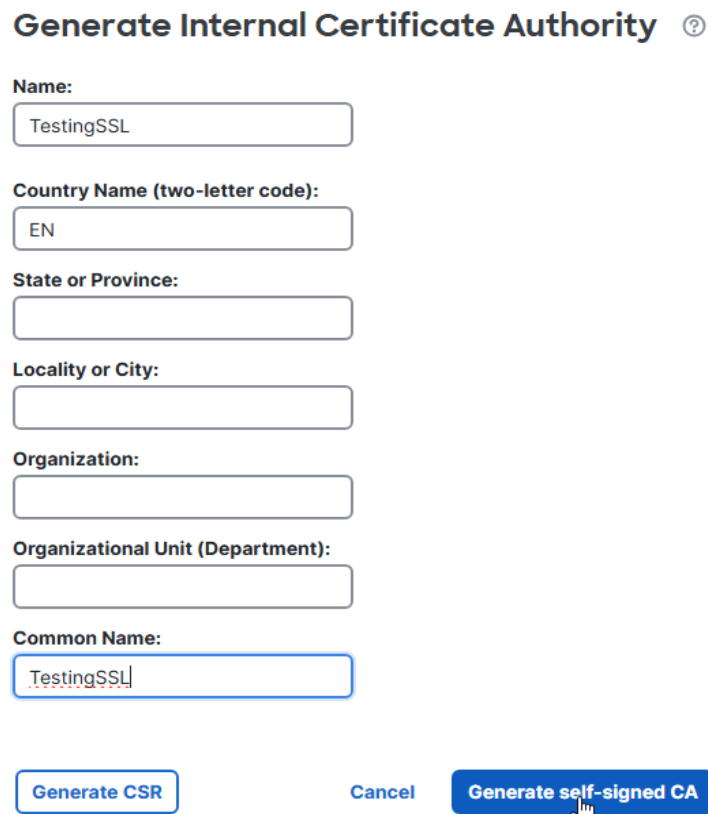


Figure 9 — Internal CAs: Generate CA button

3. Fill in the certificate details (Name, Country, Common Name) and click Generate Self-Signed CA.



Generate Internal Certificate Authority ?

Name:

Country Name (two-letter code):

State or Province:

Locality or City:

Organization:

Organizational Unit (Department):

Common Name:

Figure 10 — Generate Internal Certificate Authority form

4. Download the certificate (PKCS#12 format with both keys).
5. Use OpenSSL to extract the public key (the only key clients need):

```
openssl pkcs12 -nocerts -in Test.p12 -out Private.pem  
openssl pkcs12 -clcerts -nokeys -in Test.p12 -out Public.pem
```

```
C:\Users\user\Downloads\OpenSSL-1.1.1h_win32>openssl.exe pkcs12 -nocerts -in C:\Test.p12 -out C:\Users\user\Desktop\Private.pem  
Enter Import Password:  
Enter PEM pass phrase:  
Verifying - Enter PEM pass phrase:  
C:\Users\user\Downloads\OpenSSL-1.1.1h_win32>openssl.exe pkcs12 -clcerts -nokeys -in C:\Test.p12 -out C:\Users\user\Desktop\Public.pem  
Enter Import Password:
```

Figure 11 — OpenSSL key extraction commands

7. Install CA on Client Machines

In production environments, the CA certificate is distributed via Group Policy (GPO). In this lab, we install it manually.

1. On the client machine, run certmgr.msc.
2. Navigate to Trusted Root Certification Authorities → Certificates.
3. Right-click → All Tasks → Import.
4. Browse to the Public.pem file and complete the import wizard.

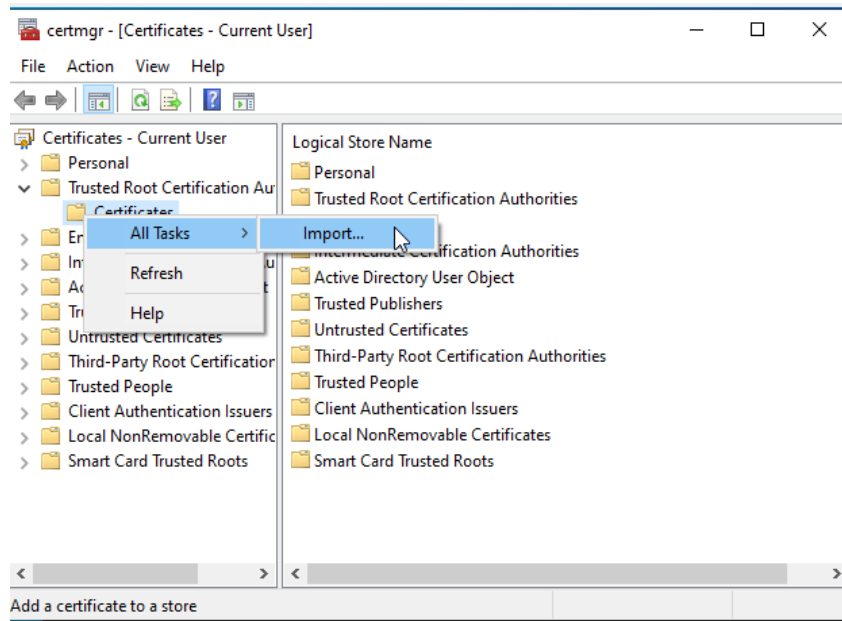


Figure 12 — Certificate Manager: Import to Trusted Root

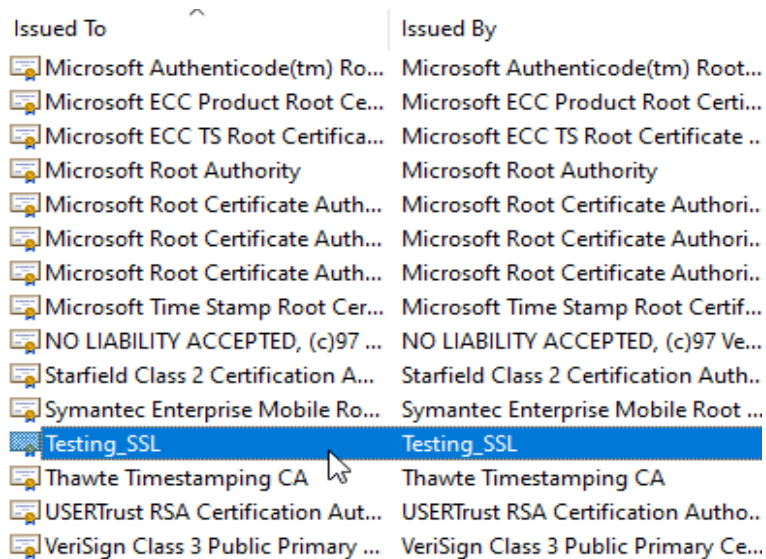


Figure 13 — Testing_SSL certificate installed in Trusted Root store

8. Create SSL Decryption Policy

1. Navigate to Policies → Access Control → Decryption.
2. Click New Decryption Policy.
3. Name the policy (e.g., SSL_Test) and select the Internal CA (Testing_SSL).

i A decryption policy is not required to only perform application or URL discovery; instead, you can use TLS 1.3 Server Identity Discovery on the access control policy.

Name *

Description

Outbound Connections (User Protection) **Inbound Connections (Server Protection)**

How Outbound Protection Works
 Outbound protection matches traffic based on the referenced internal CA certificate's signature algorithm type, in addition to any configured rule conditions.

Internal CA
 A rule will be auto-created for the selected certificate authority.

[No networks/ports associated](#) [Download](#)

[See how to configure](#)

[Cancel](#) [Skip](#) [Next](#)

Figure 14 — Create Decryption Policy: Policy Details (CA selection)

► 8.1 Step 2 — Blocking (Optional)

Configure blocking for insecure TLS versions and invalid certificates:

- Block SSL v3.0, TLS v1.0, and TLS v1.1 connections
- Block Invalid Signature, Expired, and Not Yet Valid certificates

Create Decryption Policy

1 Policy Details — 2 **Blocking** — 3 Decryption Exclusions

Enter name, description, choose policy type and certificates.
 (Optional) Configure blocking based on TLS version and certificate status.
 (Optional) Configure exclusions for outbound connections.

☒ **Block inbound and outbound connections based on TLS version**
 We recommend blocking the following because they are not secure.
 [Reset to default](#)

☒ **Block inbound and outbound connections based on server certificate status**
 We recommend blocking the following because they are not secure.
 [Reset to default](#)

[Cancel](#) [Skip](#) [Back](#) [Next](#)

Figure 15 — Decryption Policy: Blocking insecure TLS versions & bad certs

► 8.2 Step 3 — Decryption Exclusions

Some categories should NOT be decrypted for regulatory, compliance, or privacy reasons:

- Banking, Government, Healthcare
- Microsoft / Google / Apple updates

- Undecryptable distinguished names (56 included by default)
- Undecryptable applications using certificate pinning (56 included)

Create Decryption Policy

1 Policy Details Enter name, description, choose policy type and certificates.

2 Blocking (Optional) Configure blocking based on TLS version and certificate status

3 Decryption Exclusions (Optional) Configure exclusions for outbound connections.

Decryption Exclusions

☐ **Bypass decryption for sensitive URL categories**
In many environments, certain categories of websites are not inspected for regulatory, compliance or privacy reasons. Customize the list below to bypass inspection for designated categories.
Note: **URL License is Required**

URL Categories: **Health and Medicine** × **Finance** × **Online Trading** × **+ Add**

☒ **Bypass decryption for undecryptable distinguished names**
Bypass decryption based on Cisco's list of known undecryptable distinguished names.
Note: **This option is selected by default to allow traffic which cannot be decrypted to remain encrypted. Disabling this option might cause decryption to fail for unsupported distinguished names.**

56 Distinguished names included ▾

☒ **Bypass decryption for undecryptable applications**
Certain enterprise applications are not supported for decryption due to a variety of reasons (Certificate Pinning, Client Certificate Authentication, etc.). Bypass decryption based on Cisco's list of known undecryptable applications.
Note: **This option is selected by default to allow traffic which cannot be decrypted to remain encrypted. Disabling this option might cause decryption to fail for unsupported applications.**

56 Applications included ▾

Figure 16 — Decryption Exclusions: bypass for sensitive categories

► 8.3 Add Decryption Rule

Create a Decrypt-Resign rule with the Internal CA, applying to traffic from Inside_zone to Outside_zone:

Add Rule

Name: ☒ Enabled Insert:

Action: with ☒ Replace Key Only

Zones Networks VLAN Tags Users Client Threat Applications Ports Category Certificate DN Cert Status Cipher Suite Version Logging

Available Zones

Inside_zone
Outside_zone

Add to Source
Add to Destination

Source Zones (1)
Inside_zone

Destination Zones (1)
Outside_zone

Cancel **Add**

Figure 17 — Decryption Rule: Decrypt-Resign with Testing_SSL CA

► 8.4 Attach to Access Control Policy

The decryption policy must be referenced from your ACP to take effect:

1. Go to Policies → Access Control → your ACP → Advanced.
2. Under SSL Policy, select your decryption policy (SSL_Test).
3. Save → Deploy.

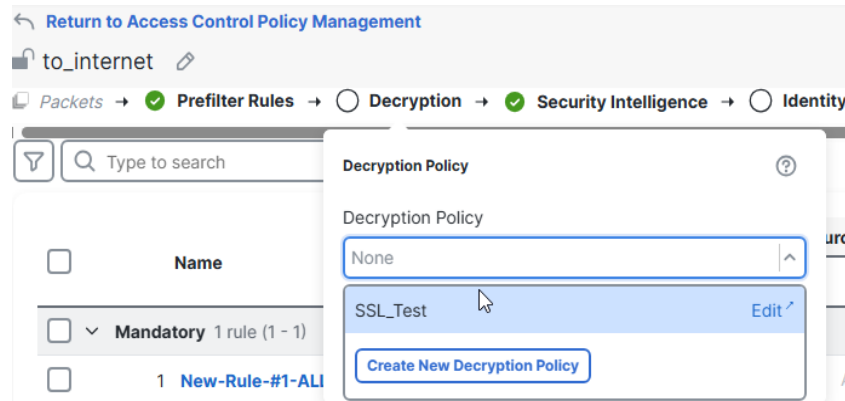


Figure 18 — ACP Advanced: SSL_Test policy attached

9. Verification

► 9.1 Certificate Verification

After deploying the SSL policy, browse to any HTTPS site and inspect the certificate. Before decryption, the certificate was issued by the original CA (e.g., WR2 for Google). After applying the policy, the certificate is now issued by Testing_SSL — confirming FTD is performing Decrypt-Resign:

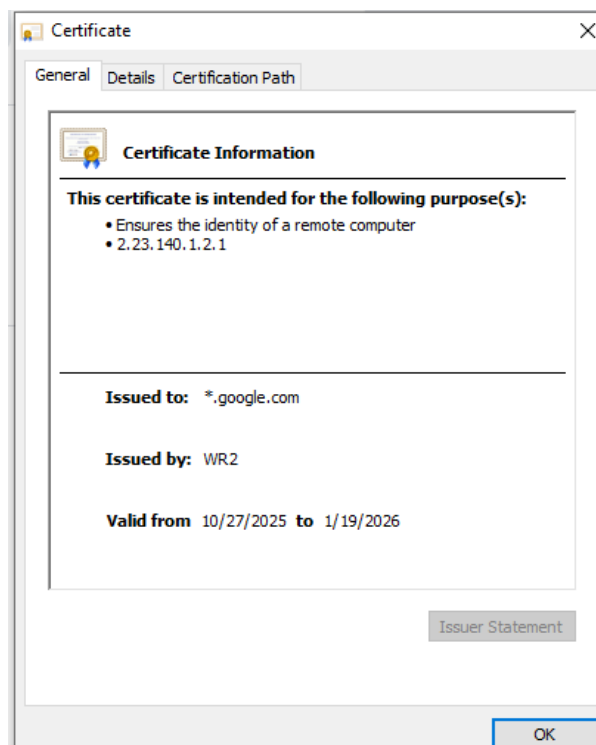


Figure 19 — Certificate BEFORE: Issued by WR2 (original CA)

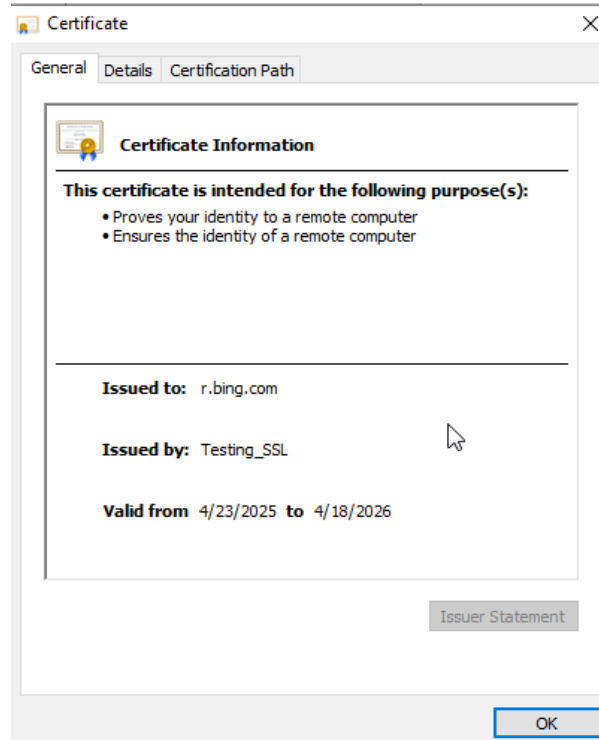


Figure 20 — Certificate AFTER: Issued by Testing_SSL (FTD CA)

If you see "Issued by: Testing_SSL" → the SSL Decryption policy is working correctly.

► 9.2 badssl.com Validation

Test the decryption policy against badssl.com, which provides endpoints with various certificate issues (expired, revoked, wrong host, self-signed):

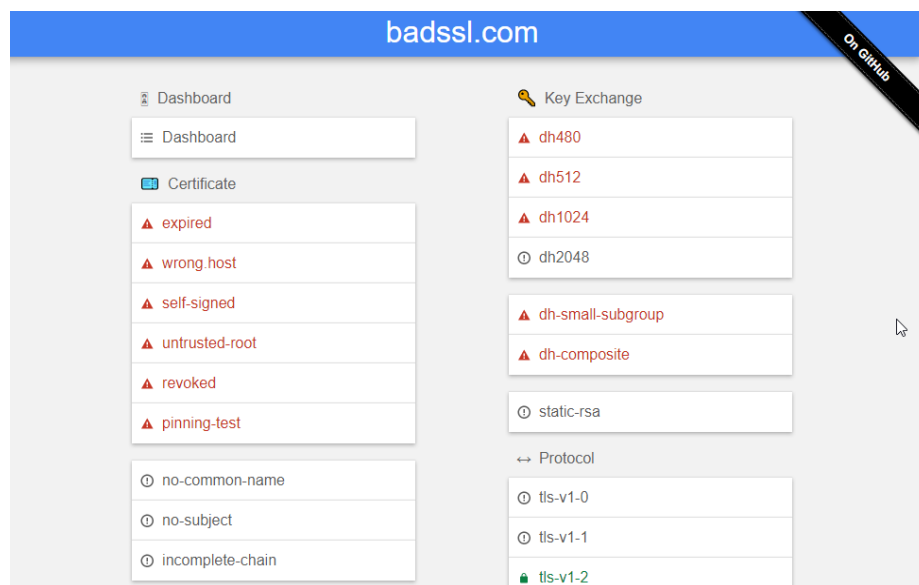


Figure 21 — badssl.com test dashboard

Expired certificates (expired.badssl.com) should be blocked by the decryption policy's certificate status rules:

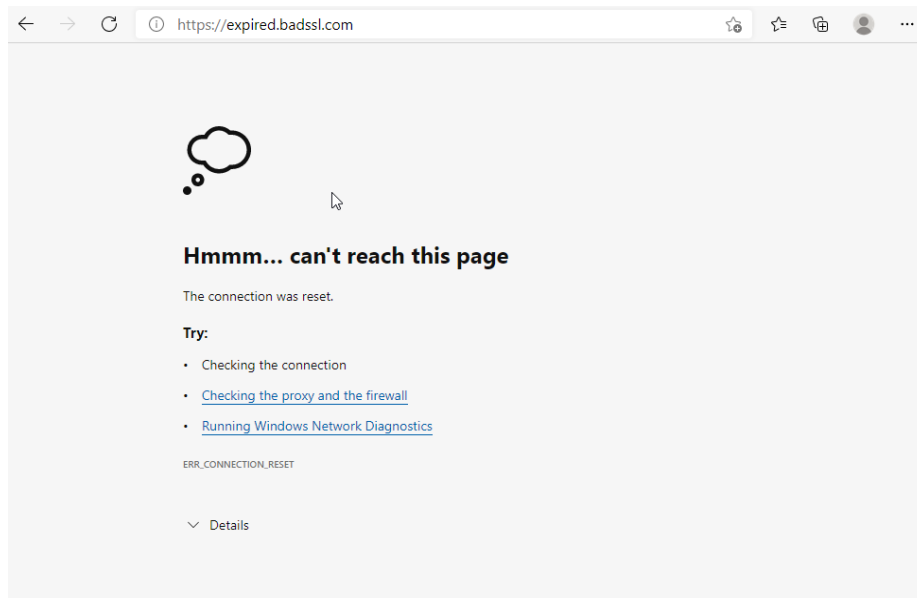


Figure 22 — expired.badssl.com blocked: ERR_CONNECTION_RESET

► 9.3 Certificate Status Rule

The decryption rule's Cert Status tab allows granular control over certificate validation — block revoked, expired, invalid signature, self-signed, and server mismatch certificates:

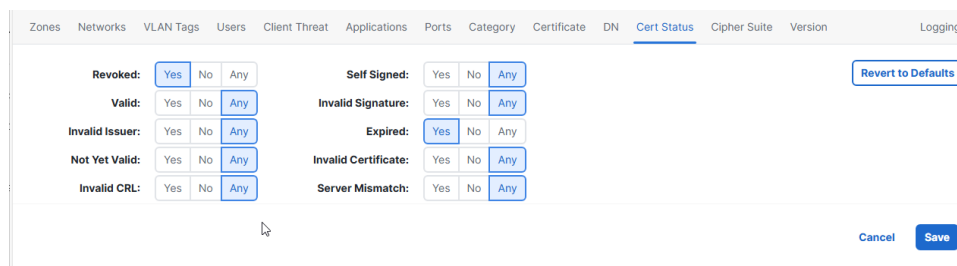


Figure 23 — Cert Status tab: granular certificate validation controls

10. Troubleshooting

► 10.1 Browser Warns "Connection Not Secure"

- The internal CA is not installed in the Trusted Root Certification Authorities store
- Fix: Reinstall the CA under Local Machine → Trusted Root (or deploy via GPO in production)

► 10.2 Decryption Not Working

- SSL policy not attached to the ACP — the policy is not applied until referenced from Advanced settings
- Decryption exclusions bypassing the target site — check if the domain falls under an excluded category
- Certificate pinning — some applications refuse re-signed certificates (e.g., banking apps)

11. Summary

Component	Details
URL Filtering	Classify and enforce web traffic by category, reputation, and URL
SSL Decryption Mode	Decrypt-Resign (man-in-the-middle proxy)
Internal CA	Generated in FMC → Objects → PKI → Internal CAs
Client Trust	Public CA certificate installed in Trusted Root store
Decryption Exclusions	Banking, Government, Healthcare, certificate-pinned apps
Block Insecure TLS	SSL v3.0, TLS v1.0, TLS v1.1 blocked by default
Rule Order	Block rules → Allow rules → Default rule (top-down)
Verification	Check certificate issuer in browser (should show FTD CA)
Validation	badssl.com for expired/revoked/self-signed cert testing
